

PRIVACY POLICY

Version 1.1

Revision Date: August 28, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Privacy Policy
Document ID	POL-PRIV-001
Current Version	1.1
Approved Date	August 28, 2026
Approved By	Information Security Steering Committee
Effective Date	August 28, 2026
Next Review Date	August 28, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	POL-PRIV-001 v1.0
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001). The Privacy category of the Trust Services Criteria is not in the scope of the Company's current examination; this Policy records that position and states the obligations the Company carries under data protection law regardless. It also records how personal data is protected and to whom it is disclosed, so that the position stated in the published Privacy Notice has an internal control behind it.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE	5
2 SCOPE	5
3 ROLES AND DEFINITIONS.....	5
4 TERMINOLOGY	5
5 WHAT THE COMPANY PROCESSES	6
6 OBLIGATIONS THE COMPANY CARRIES	6
7 HOW THE COMPANY PROTECTS PERSONAL DATA	7
8 HOW THE COMPANY SHARES PERSONAL DATA	8
9 RECORDS.....	8
10 EXCEPTIONS.....	9
11 REFERENCE.....	9
12 DOCUMENT POLICY HISTORY.....	9

1 Overview and Purpose

PromptHalo Technologies (“the Company”) processes personal data — its own personnel records, and client personal data as a processor. This Policy says what it does with both.

The Privacy category of the Trust Services Criteria is not in scope for the current examination. That is a scoping decision, recorded here and in the risk register, and it is revisited when a client agreement requires the category or when the Company begins acting as a controller for material volumes of personal data.

2 Scope

This Policy covers personal data the Company holds about its own personnel and candidates, and personal data it processes on behalf of clients.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. The Accountable Party handles data subject requests and decides, with external advice where needed, whether the Company is acting as controller or processor for a given processing activity. [SOC 2: CC1.3 · GDPR Art. 28]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
3. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
4. **Controller** — the party that decides why and how personal data is processed.
5. **Cross-context behavioral advertising** — advertising to a person based on personal data obtained from their activity across businesses or services other than the one they are dealing with. The Company does not engage in it.
6. **Data subject request** — a request from an individual to exercise a right over their personal data.
7. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.

8. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]
9. **Personal data** — information relating to an identified or identifiable individual, including personal information as US state privacy law defines it.
10. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
11. **Processor** — a party that processes personal data on a controller's instructions.
12. **Security Officer** — the individual accountable for day-to-day operation of the security program.
13. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
14. **Sub-processor** — a processor engaged by the Company to process personal data on a client's behalf, under the terms of the Company's agreement with that client.
15. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

5 What the Company Processes

1. As controller: personnel and candidate records, held under the Human Resources Security Policy and the Screening Standard, and retained under the Data Retention, Disposal and Disaster Recovery Policy. [SOC 2: CC2.1 · GDPR Art. 5, 6]
2. As processor: client personal data encountered during engagements, processed only on the client's instructions and under the terms of the engagement agreement. [SOC 2: CC9.2 · GDPR Art. 28]
3. The Company does not sell personal data, does not use client personal data to train models, and does not process personal data for its own purposes beyond running the business. [SOC 2: CC9.2 · GDPR Art. 6]

6 Obligations the Company Carries

1. Personal data is collected only where there is a basis for it, kept only as long as the retention schedule allows, and protected to the standard the Data Classification and Encryption Policies set. [SOC 2: CC6.7 · GDPR Art. 5, 32]
2. Sub-processors handling client personal data are recorded on the sub-processor list and notified to clients under the Vendor Management Policy. [SOC 2: CC9.2 · GDPR Art. 28]

3. A personal data breach is handled as an incident, and the notification obligations in the notification matrix govern who is told and by when. Where the Company is a processor, it notifies the controller without undue delay. [SOC 2: CC7.4 · GDPR Art. 33]
4. A data subject request received by the Company as controller is acknowledged and answered within the period the applicable law allows. A request relating to client data is passed to the client, which is the controller, rather than answered by the Company. [SOC 2: CC2.3 · GDPR Art. 12, 15]
5. What the Company tells website visitors, enquirers and customer contacts about its processing is set out in the published Privacy Notice, which is the Company's Article 13 and 14 disclosures. This Policy governs the internal position; the Notice is what the public sees, and the two are reviewed together so they cannot drift apart. [SOC 2: CC2.3 · GDPR Art. 13, 14]

7 How the Company Protects Personal Data

The controls that protect personal data are the controls that protect everything else. This section records which of them carry the privacy obligation, so that the claim made in the Privacy Notice can be traced to something that operates.

1. Personal data is classified and handled under the Data Classification Policy, and encrypted in transit and at rest to the standard the Encryption Policy sets. [SOC 2: CC6.1, CC6.7 · GDPR Art. 32]
2. Access to personal data is granted on least privilege, requires multi-factor authentication, is reviewed at the cadence the Access Control Policy sets, and is removed on separation. [SOC 2: CC6.1, CC6.2, CC6.3 · GDPR Art. 32]
3. Personnel with access to personal data are screened under the Screening Standard, are bound by confidentiality terms, and complete privacy and security awareness training. [SOC 2: CC1.4, CC2.2 · GDPR Art. 32(4)]
4. Access to systems holding personal data is logged and monitored, so that an unauthorized access is capable of being detected rather than assumed not to have happened. [SOC 2: CC7.2 · GDPR Art. 32]
5. Availability and restorability of personal data are governed by the Data Retention, Disposal and Disaster Recovery Policy, including the backup, recovery objectives and restoration testing it requires. [SOC 2: A1.2 · GDPR Art. 32(1)(c)]
6. Production personal data is not used in development or test environments unless it has been de-identified. Where that is not practicable, the Accountable Party approves the use and records it with a review date. [SOC 2: CC6.1 · GDPR Art. 5(1)(c)]
7. Safeguards are reassessed on any significant change and at the annual review. The Company does not state a standard of protection it has not tested. [SOC 2: CC3.2 · GDPR Art. 32(1)(d)]

8 How the Company Shares Personal Data

The Company does not sell personal data. It does disclose personal data to the service providers it runs on, which is a different thing. This section keeps the two apart, so that neither statement has to be qualified later.

1. The Company does not sell personal data and does not share it for cross-context behavioral advertising as US state privacy law defines those terms. It does not disclose personal data to any third party for that party's own purposes. [SOC 2: CC9.2 · CPRA §1798.120]
2. Personal data is disclosed to sub-processors and service providers acting on the Company's documented instructions under written contract, and only so far as they need it to perform. Each is recorded on the sub-processor list. [SOC 2: CC9.2 · GDPR Art. 28]
3. A sub-processor is assessed before engagement and reassessed under the Vendor Management Policy. Clients are notified before a new sub-processor begins processing their personal data, on the terms the engagement agreement sets. [SOC 2: CC9.2 · GDPR Art. 28(2)]
4. Client personal data is processed only on the client's documented instructions and is not used for any purpose of the Company, including training or evaluating models, whether the Company's own or a provider's. Where a commercial AI service is used in delivery, it is used under terms that exclude submissions from provider training. [SOC 2: CC9.2 · GDPR Art. 28(3)(a)]
5. Personal data transferred out of the UK or the EEA moves under the Standard Contractual Clauses with the UK Addendum, or under an adequacy decision, with a transfer assessment recorded where one is needed. [SOC 2: CC9.2 · GDPR Art. 46]
6. Personal data is disclosed to law enforcement, a regulator or a court only where the Company is legally required to do so, or to establish or defend a legal claim. The disclosure is recorded, and the client is told where the Company is permitted to tell them. [SOC 2: CC2.3 · GDPR Art. 6(1)(c)]
7. On a merger, acquisition or sale of the business, personal data may transfer to the acquiring entity subject to this Policy, and affected clients are told before it does. [SOC 2: CC9.2]
8. Any disclosure not described above is approved in advance by the Accountable Party and recorded. [SOC 2: CC9.2]

9 Records

1. The scoping decision recording that the Privacy category is out of scope, with its review date. [SOC 2: CC3.2]
2. The record of processing activities, so far as one is required. [SOC 2: CC2.1 · GDPR Art. 30]
3. The sub-processor list and client notifications. [SOC 2: CC9.2]
4. Data subject requests received and how they were handled. [SOC 2: CC2.3]
5. The published Privacy Notice and its version history. [SOC 2: CC2.3]
6. The transfer mechanisms relied on, with any transfer assessments. [SOC 2: CC9.2 · GDPR Art. 46]

7. Disclosures made under legal compulsion, with what was disclosed and to whom. [SOC 2: CC2.3]

8. Approvals for any use of personal data outside a production environment. [SOC 2: CC6.1]

10 Exceptions

Where a client agreement requires the Privacy category to be in scope, or requires obligations beyond this Policy, that requirement governs and this Policy is reissued rather than an exception being recorded.

11 Reference

1. SOC 2 Trust Services Criteria, Security category [CC2.1, CC2.3, CC7.4, CC9.2]
2. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
3. POL-VM-001 Vendor Management Policy [SOC 2: CC9.2]
4. POL-IRP-001 Incident Response Policy [SOC 2: CC7.4]
5. POL-DRD-001 Data Retention, Disposal and Disaster Recovery Policy [SOC 2: CC6.5]
6. POL-DCL-001 Data Classification Policy [SOC 2: CC2.1]
7. EU General Data Protection Regulation, Articles 5, 6, 12, 15, 28, 30, 32, 33 and 46
8. POL-ENC-001 Encryption Policy [SOC 2: CC6.7]
9. California Consumer Privacy Act as amended by the CPRA, §§1798.100–1798.199

12 Document Policy History

Version	Date	Description
1.0	August 18, 2026	Initial policy release
1.1	August 28, 2026	Added How the Company Protects Personal Data and How the Company Shares Personal Data. Terminology, records and references extended. Cross-references updated for the retitled POL-DRD-001.